

FinTech Track 1: Agentic Commerce Trust 与市场研究报告

1. 核对专有名词 (Proper Nouns Verification)

- 香港企业电子身份项目
 - 官方名称：“智方便” (iAM Smart) / 企业版“智方便” (e-PY / Corporate iAM Smart / 商业电子身份)。
 - 官方发布/主管机构：香港特别行政区政府数字政策办公室 (Digital Policy Office)。
 - 应用场景：提供企业及商家的法定身份电子验证，避免仅依赖纸本营业登记 (BR) 副本带来的冒用风险。
- 中国数字身份项目
 - 官方名称：国家网络身份认证 (National Network Identity Authentication) / 居民身份网络凭证 (CTID)。
 - 官方发布/主管机构：中华人民共和国公安部、国家互联网信息办公室。
 - 应用场景：基于可信根的数字身份凭证，实现去中心化的身份验签与网络实名。
- 通用/行业标准协议
 - 金融报文标准：ISO 8583 (开放式支付网络如 Visa/Mastercard/银联的交易报文标准)。
 - 代理支付协议：Agentic Commerce / Agentic Payment Protocol (如 Google AP2 / Universal Payment Protocol)。

2. 设计双向验证链 (Bidirectional Authentication Chain)

在 Agentic Commerce (代理商业) 模式下，信任必须是双向的 (Mutual Trust)：平台与商家需验证买家及其 Agent 的真实性；买家与 Agent 也必须验证商家的合法性与行为合规性。

2.1 身份与授权证明定义 (Credentials Required)

1. 买家 (Buyer)：

- **根信任 (Root of Trust)**：基于政府法定数字身份（香港 iAM Smart / 内地 CTID）签发的验证凭证。
- **代理委托书 (Delegation Mandate)**：买家给 Agent 签发的加密授权书，明确约定授权范围（Scope）、交易金额上限（Cap，如港币 \$2,000 以内）、有效期限（Expiry）及可交易的商家白名单。

2. AI Agent (代理)：

- **Agent 绑定证书**：基于设备硬件安全芯片（Secure Enclave）或软件密钥生成的 Agent 签名凭证，证明该 Agent 为特定买家合法授权的代理实体。

3. 商家 (Merchant)：

- **企业身份凭证**：通过 Corporate ID / 企业版“智方便” (e-PY) 或法定商业登记 (Business Registration) 认证的电子证书。

2.2 验证流程 (Verification Workflows)

1. 授权下发：

买家使用法定数字身份签名生成 Delegation Mandate，将其下发给 Agent。

2. 双向建立：

Agent 代表买家与商家建立连接时，向商家出示包含买家 Mandate 与 Agent 签名的数据包；同时要求商家提供电子企业身份凭证（e-PY）。

3. 验签与清算：

商家将 Agent 提交的凭证送往清算网关/模拟银行节点，校验签名合法性、授权额度及有效期限；网关确认无误后划扣款项。

2.3 异常拒绝与防御机制 (Exception & Refusal Mechanics)

- **凭证过期 (Expired Credentials)**：超过授权有效期，清算网关直接拒绝交易，返回 401 Unauthorized，并要求 Agent 触发买家重新授权流程。

- **凭证撤销 (Revocation)**：用户可在客户端随时撤销授权。撤销状态同步至联机撤销列表 (CRL/OCSP)，Agent 发起的任何后续交易均被拒绝。
- **越权与防冒用 (Over-cap/Impersonation Refusal)**：若 Agent 单笔交易超额（如超过 \$2,000 限额）或在非白名单商家消费，网关将自动挂起交易并向买家推送信道，要求强身份验证 (Step-up Auth)。

3. 研究风险案例 (Risk Case Studies)

单次静态的身份验证只能证明“当下是谁”，无法防范后续的违规行为。必须结合持续的行为控制机制。

案例 1：

真实营业登记商家滥用顾客资料 (Malicious/Compromised Merchant)

- **场景描述**：商家拥有合法合规的商业登记 (BR)，但当买家或 Agent 在该商家完成一次合法购物并留下信用卡/支付凭证后，商家私自留存该敏感资料，或将其转卖给黑客在其他平台刷卡。
- **单次验证之外的控制措施**：
 - **一次性虚拟凭证 (Scoped Single-Use Token)**：Agent 不直接传达真实信用卡号，而是传递针对该商家、该笔交易动态生成的单次 Token (One-Time Token)。
 - **零知识证明 (ZKP) / 数据最小化**：限制商家获取买家敏感信息的权限，仅提供交货所需的必要加密信息。
 - **持续行为监控与可追溯日志**：平台在后台对商家退款率、盗卡投诉率进行实时风控，一旦发现异常行为立即取消其企业身份认证并阻断清算。

案例 2：

盗用他人身份或卡资料的坏买家 (Fraudulent Buyer)

- **场景描述**：攻击者通过非正当渠道窃取了他人的支付凭证，并配置到自身的 Agent 中，试图利用 Agent 的自动下单能力进行高频刷单或转移资产。
- **单次验证之外的控制措施**：
 - **频次与速度控制 (Velocity Checks)**：系统限制特定凭证/Agent 在短时间内的交易频次与总额，触发阈值即暂停自动化交易。

- **风险触发二次确认 (Step-up Step Authentication)**：当 Agent 检测到异常 IP 地址、新设备或高风险商品类型时，要求强制拉起买家手机进行生物识别 (FaceID/指纹) 二次确认。

4. 研究 OTP 与设备方案 (OTP & Device Trust Assessment)

4.1 OTP (SMS/Email) 的局限性

- **安全性不足**：OTP 易受到 SIM 拦截 (SIM Swapping)、伪基站拦截及社会工程学钓鱼攻击。
- **阻断 Agent 自动化**：OTP 依赖人工接收并输入验证码，会直接中断 Agent 的无缝代理交易流程，不符合 Agentic Commerce 的核心体验要求。
- **无密码学非对称绑定**：无法实现不可抵赖性 (Non-repudiation)。

4.2 替代方案评估 (Device Certificate / Soft Token)

- **信任来源**：基于硬件安全芯片 (Secure Enclave / TPM) 生成的设备证书或软令牌 (Soft Token)，利用非对称加密 (PKI) 将私钥安全存储于设备内部。
- **验证步骤**：
 1. 初始化：买家设备向平台注册，公钥上传，私钥存入安全芯片。
 2. 交易时：Agent 请求设备安全芯片对交易摘要 (Hash) 进行私钥签名。
 3. 服务端验签：清算端利用公钥校验签名。
- **用户体验成本**：一次绑定，后续由 Agent 后台自动代完成签名验证，仅在大额交易时拉起指纹/FaceID，极大地降低了用户操作复杂度。

4.3 实施对比 (48 小时 Demo vs. 真实部署)

评估维度	48 小时黑客松模拟 (Demo Implementation) PNG	真实生产部署 (Production Requirements) PNG
身份源 (Identity Root)	本地 Mock / 自签名 JWT 令牌 模拟买家与商家身份	对接香港数字政策办公室 iAM Smart API / 内地公安部 CTID

评估维度	48 小时黑客松模拟 (Demo Implementation) PNG	真实生产部署 (Production Requirements) PNG
设备信任 (Device Trust)	软件生成的 RSA/ECC 密钥对，存入 LocalStorage 或应用私钥文件	基于硬件级 Secure Enclave 芯片 + MDM 证书托管与管理
清算与防重放	模拟银行 (Fake Bank)：构建简易 API 实现借贷记 (Debit/Credit) 账目增减	接入真实支付网络 (ISO 8583 报文、Visa/Mastercard 或 FPS 接口)
风控规则引擎	简单的硬编码逻辑 (如 if (amount > 2000) reject())	复杂的多维度实时风控系统 (设备指纹、行为生物识别、实时评分)

5. 比较目标市场 (Target Market Comparison)

5.1 场景数据与特性对比

市场区域	支付基础设施	身份认证基础设施	Agentic Commerce 主要痛点与价值
香港 (Hong Kong)	信用卡、转数快 (FPS) 普及率高；国际汇率结算灵活。	“智方便” (iAM Smart) 及企业版逐步推广。	商家认证成本高、信用卡盗刷风险；Agent 自动化比价与受控代扣需求强。
内地 (Mainland China)	移动支付 (微信 / 支付宝) 占绝对主导；自动化扣款风控极严格。	国家网络身份认证 (CTID) 与微信 / 支付宝实名极其成熟。	平台闭环较强；Agent 代扣授权需要极高的合规与合规限制。

市场区域	支付基础设施	身份认证基础设施	Agentic Commerce 主要痛点与价值
跨境场景 (Cross-Border)	多币种、汇率转换、不同卡组织及清算轨道。	存在跨国/跨地区身份互认与隐私法规差异 (GDPR vs PIPL)。	痛点最突出：买卖双方信任壁垒高、身份核验困难、欺诈成本高。

5.2 首发市场建议与理由

- 首发市场定位：香港本地及“香港-内地/海外”跨境电商场景 (Hong Kong & Cross-Border E-Commerce)。
- 核心理由：
 1. 金融体系开放：香港拥有成熟的卡组织 (Visa/Mastercard) 及转数快 (FPS) 体系，便于构建代扣款与清算逻辑。
 2. 信任需求迫切：跨境电商中买卖双方缺乏天然信任，通过“企业 BR/iAM Smart 验证商家”与“受控 Mandate 保护买家”能带来最高的商业价值。
 3. 商业模式可行：可以在规模 (Scale) 与利润率 (Margin) 之间取得较好平衡 (高客单价跨境商品能提供更高的单笔 Margin)。

5.3 采用动机 (Adoption Incentives)

- 买家 (Buyers)：彻底解放手工比价与重复输入的繁琐流程；通过设定明确的权限与限额 (Cap)，无须担心信用卡资料泄露或被商家滥用。
- 商家 (Merchants)：大幅降低结账环节的弃单率 (Checkout Friction)；通过密码学验证获得确定性更高的付款保障，降低坏账与欺诈风险。